

SIT 218/738: Secure coding:

OnTrack Task 2.2P Activity:

LLM based threat modelling

Traditional manual threat modeling is very time-consuming. In addition, comprehensive and effective threat modeling that covers all potential vulnerabilities requires expert-level knowledge. Such expertise may not always be available and can be expensive for many organizations. Therefore, to improve reliability, cybersecurity team members can leverage AI-based threat modeling and cross-check the results against their manually developed threat models to identify any vulnerabilities or related threats that may have been overlooked. Deep learning-based Large Language Models (LLMs) [2] are a type of Artificial Intelligence (AI) model. LLMs use transformer-based neural networks. When trained on sufficiently large text corpora, LLMs can generate language outputs that closely resemble natural human language.

In this activity, we will use an LLM to identify the elements of a Data Flow Diagram (DFD) and the related threats. We will also classify these threats using the Common Attack Pattern Enumeration and Classification (CAPEC) framework, identify threat scenarios, and determine appropriate mitigation techniques.

The Common Attack Pattern Enumeration and Classification (CAPEC) [1] is a publicly available attack pattern database. It provides a catalog of known attack patterns used by adversaries. CAPEC helps cybersecurity teams classify attacks into recognized categories, making it easier to identify appropriate mitigation techniques. By understanding the key components of various attacks, organizations can implement effective measures to prevent and defend against them.

Please note that pre-trained LLMs are computationally expensive. As a result, this activity may take some time to complete, depending on the system resources available. This activity uses a modified version of an open-source tool [2]. The tool has been customized to support our VM lab environment.

Reference:

[1]<https://capec.mitre.org/>

[2] Sammouri, Karim and Walden, James, A Large Language Model Based Threat Modeling Tool with CAPEC Semantic Retrieval. Available at SSRN: <https://ssrn.com/abstract=5242954> or <http://dx.doi.org/10.2139/ssrn.5242954>

Now follow the below steps to complete this activity.

Step-1: Start LLM and Check which olama models are running,

```
$ ollama list
```

you should see as:

NAME	ID	SIZE	MODIFIED
llama3.2:1b	baf6a787fdff	1.3 GB	4 days ago
qwen3:4b	359d7dd4bcda	2.5 GB	4 days ago

Step-2: Activate the environment: write following command in your terminal:

```
$ cd ~/capec_threat_modeling
$ export TRANSFORMERS_OFFLINE=1
$ export HF_DATASETS_OFFLINE=1
$ export HF_HUB_OFFLINE=1
$ source venv/bin/activate
```

Step-3: Start the Flask application in the back end

```
$ python3 app.py
```

You should see as:

Warning: You are sending unauthenticated requests to the HF Hub. Please set a HF_TOKEN to enable higher rate limits and faster downloads.

```
.....
.....
```

- * Running on all addresses (0.0.0.0)
- * Running on http://127.0.0.1:5000
- * Running on http://10.0.2.15:5000

Press CTRL+C to quit

- * Restarting with stat
- * Debugger PIN: 142-444-250

```
(venv)kali@kali: ~/capec_threat_modeling
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)~$ ollama list
NAME      ID              SIZE    MODIFIED
llama3.2:1b  baf6a787fdff  1.3 GB  4 days ago
qwen3:4b    359d7dd4bcda  2.5 GB  4 days ago
(kali@kali)~$ ollama serve
Error: listen tcp 127.0.0.1:11434: bind: address already in use
(kali@kali)~$ curl http://127.0.0.1:11434/api/tags
{"models":[{"name":"llama3.2:1b","model":"llama3.2:1b","modified_at":"2026-06-17T06:54:46.455675209-04:00","size":1321098329,"digest":"baf6a787fdff633537aa2eb51cfd54cb93ff08e28040095462b
b63da9f592878","details":{"parent_model":"","format":"gguf","family":"llama","families":["llama"],"parameter_size":"1.2B","quantization_level":"Q8_0","context_length":131072,"embedding_len
gth":2048},"capabilities":{"completion","tools"}},{"name":"qwen3:4b","model":"qwen3:4b","modified_at":"2026-06-17T04:30:34.945480175-04:00","size":2497293931,"digest":"359d7dd4bcdab3d86b8
7d73ac27966f4dbb9f5efdfcc75d34a8764a09474fae7","details":{"parent_model":"","format":"gguf","family":"qwen3","families":["qwen3"],"parameter_size":"4.0B","quantization_level":"Q4_K_M","co
ntext_length":262144,"embedding_length":2560},"capabilities":{"completion","tools","thinking"}}]}
(kali@kali)~$ cd ~/capec_threat_modeling
(kali@kali)~/capec_threat_modeling$ source venv/bin/activate
(venv)kali@kali:~/capec_threat_modeling$ python3 app.py
Warning: You are sending unauthenticated requests to the HF Hub. Please set a HF_TOKEN to enable higher rate limits and faster downloads.
Loading weights: 100% | 103/103 [00:00<00:00, 295.19it/s]
* Serving Flask app 'app'
* Debug mode: on
WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
* Running on all addresses (0.0.0.0)
* Running on http://127.0.0.1:5000
* Running on http://10.0.2.15:5000
Press CTRL+C to quit
* Restarting with stat
Warning: You are sending unauthenticated requests to the HF Hub. Please set a HF_TOKEN to enable higher rate limits and faster downloads.
Loading weights: 100% | 103/103 [00:00<00:00, 8455.43it/s]
* Debugger is active!
* Debugger PIN: 142-444-250
```

Step-4:

Open Browser, and write URL: <http://127.0.0.1:5000>

You will see the main interface for this tool.

LLM-Based CAPEC Threat Modeling Tool

System Description:

Enter your system description here

Decompose system

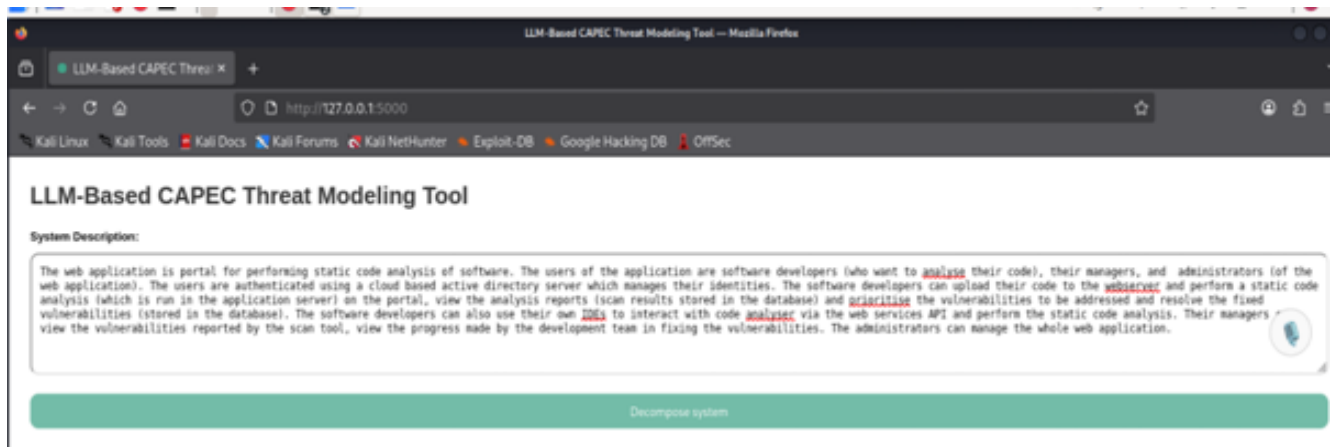
Stage 1: System Decomposition

Stage 2: Threat Identification

Stage 3: CAPEC Retrieval

Step-5: Add system description for which you are developing threat model

Copy the system description of your Task 2.1P to the system description text area of LLM based threat modeling web interface . For VM Lab, please type in the text area.



Step-6: Find the DFD

Click on the **decompose system** button and wait. This may take time as LLM takes lots of time to process.

Progress observation during execution: You will see it is progressing in the terminal (~/.capec_threat_modeling) and response come as ,

127.0.0.1 -- [22/Jun/2026 02:40:19] "GET / HTTP/1.1" 200 -

127.0.0.1 -- [22/Jun/2026 02:40:19] "GET /static/styles.css HTTP/1.1" 200 -

127.0.0.1 -- [22/Jun/2026 02:40:19] "GET /static/script.js HTTP/1.1" 200 -

127.0.0.1 -- [22/Jun/2026 02:40:19] "GET /static/favicon.svg HTTP/1.1" 200 -

--- RAW RESPONSE FOR External Entities ---

'- User\n- Administrator\n- Software Developer\n- Manager'

Once decomposed finish, it will update in the browser.





Stage 1: System Decomposition

External Entities:

- User
- Administrator
- Software Developer
- Manager

Processes:

- Authentication Service
- Payment Processing
- Portal
- Active Directory Server
- Software Developers
- Managers
- Administrators
- Code Analyzer (via IDEs)
- Vulnerability Scanner
- Database
- Development Team
- Web Application

Data Stores:

- User Database
- Transaction Log
- Active Directory Server
- Portal Database
- Code Analyzer Database
- IDE Integration Database

Step-7: Threat Identification

Then click the threat identification button:

Progress observation during execution: You will see it is progressing in the terminal (~/capec_threat_modeling) and response come as ,

External Entities

User:

- Authentication fails due to invalid username or password.
- User provides sensitive information without encryption.

Administrator:

- Login as an administrator from the web interface
- Use a compromised account or password to gain access to sensitive data

Software Developer:

- The developer may be bribed or blackmailed by a malicious external entity to compromise the system.
- A rogue developer may attempt to steal sensitive data from the company.

 **Stage 2: Threat Identification**

External Entities

User:

- Login through social media
- Send unsolicited emails or messages as a user

Administrator:

- User authentication fails when an administrator tries to access a page without proper credentials.
- An external entity (e.g. a malicious user) attempts to impersonate an administrator by accessing sensitive data or performing administrative tasks.

Software Developer:

- The developer may intentionally or unintentionally disclose sensitive information about the software development process or internal systems.
- The developer may attempt to manipulate or influence the development process through their personal opinions or biases.

Manager:

- Authentication of external entities
- Authorization based on authentication results

Processes

Authentication Service:

- Get password from user
- Validate password against database

Payment Processing:

- Extracting sensitive payment information from users without consent.
- Manipulating payment card numbers for fraudulent transactions.

Portal:

Step-7: Accomplish CAPEC classification and identify details of threats

Then Click on CAPEC retrieval:

Once retrieval finish, you will see following output.

LLM-Based CAPEC Threat Modeling Tool — Mozilla Firefox

LLM-Based CAPEC Threat × +

← → ↻ 🏠 🔒 http://127.0.0.1:5000

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

 **Stage 3: CAPEC Retrieval**

Filter Threats by Attack Likelihood: **Filter Threats by Attack Severity:**

All All

[Expand All](#) / [Collapse All](#) / [Reset Tree](#)

 External Entities

 User

 Authentication fails due to invalid username or password.

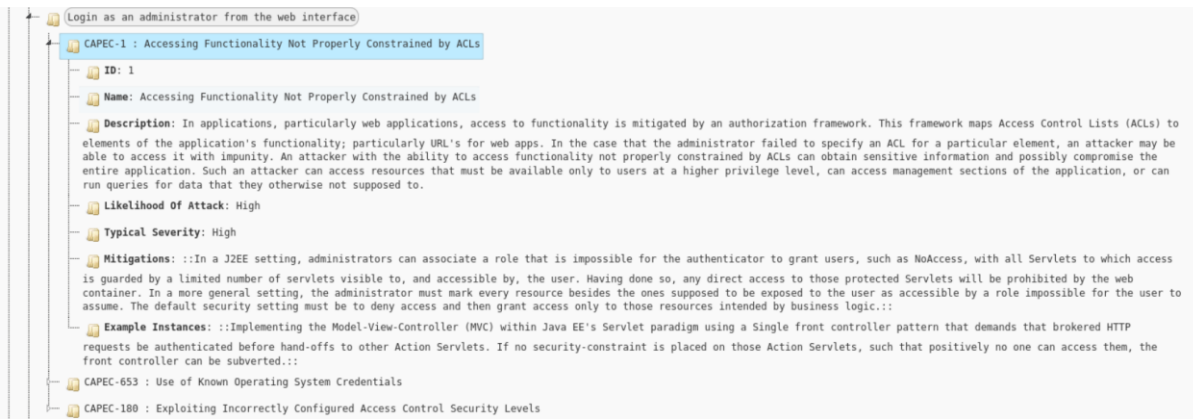
 User provides sensitive information without encryption.

 Administrator

 Login as an administrator from the web interface

Step-7: Find threat details:

Double click one of the threats, e.g **login as an administrator from the web interface**, this will show you the corresponding CAPEC threat detail, classification, threat scenarios and all other details.



Your Task: Now you understand how AI can help in delivering your organization's cyber functions. Read the references and related articles to know more about this.

Using the analysis received, compare it with the threat model you developed in Task 2.1P. Prepare a comparison table highlighting the differences between the threats identified in the two models, along with their corresponding mitigation techniques. Discuss the key differences, including any threats or mitigations that were identified in one model but not the other.

This activity forms part of Task 2.2P. Therefore, take screenshots of each step of the activity and provide a detailed explanation of what you did at each step.